

INCIDENT REPORT

Report ID: IR-2026-002

Date: 12 June 2026

Analyst: [ANJILIAH DYAVARI]

Incident Type: Phishing — Malicious File Download /
Business Email Compromise (BEC)

Severity: CRITICAL

Status: CLOSED — Contained

Source: URLhaus (abuse.ch)

Reporter: Anonymous

1. EXECUTIVE SUMMARY

A malicious PHP download script was identified hosted on a compromised legitimate business website belonging to Biduca Confeitos, a Brazilian confectionery company. The script at /download_invitee.php silently served a malicious Windows MSI installer to victims who believed they were downloading a Microsoft Teams meeting component.

The attack followed a Business Email Compromise (BEC) pattern. Victims received a spear-phishing email containing a fake Microsoft Teams meeting invitation. Clicking the meeting link triggered the download of a ConnectWise-based Remote Access

Trojan (RAT), giving the attacker full remote control over the compromised machine including access to files, credentials, camera, microphone, and internal network resources.

VirusTotal confirmed the URL as malicious with 13/92 vendor detections. Critically, Forcepoint ThreatSeeker correctly identified this as a "compromised website" — distinguishing it from a purpose-built malicious domain. The malicious PHP file has since been removed (HTTP 404).

Verdict: TRUE POSITIVE — Confirmed Malicious

Action: Block URL, purge emails, endpoint scan for RAT

2. TECHNICAL ANALYSIS

2.1 URL Details

Malicious URL:

https://biducaconfeitos.com.br/download_invitee.php

Domain: biducaconfeitos.com.br

Domain Type: COMPROMISED LEGITIMATE WEBSITE

(Brazilian confectionery/cake business)

TLD: .com.br (Brazilian commercial domain)

Status: HTTP 404 — malicious file removed

Unlike Sample A which used a purpose-built fake domain, this

attack hijacked a real legitimate small business website. Attackers compromised the site and uploaded a malicious PHP script to serve as a malware delivery point. Using a legitimate domain allows attackers to evade reputation-based blocklists that would immediately flag a new fake domain.

2.2 VirusTotal Analysis

Detection Ratio: 13 / 92 vendors flagged as malicious

First Submitted: 29 January 2026, 17:31:05 UTC

Last Submitted: 03 June 2026, 15:04:16 UTC

Last Analysis: 03 June 2026, 15:04:16 UTC

HTTP Status: 404 (file removed at time of analysis)

Serving IP: 162.241.3.47

Server: Apache

CMS Detected: WordPress 7.0

Plugins: WooCommerce 10.8.1, Elementor 4.1.1

Body SHA-256:

f64aac4532e9c19ffe67dc86399014babf3d6163e5646b57abfdf791cc1722cf

Vendor Detection Labels:

Vendor	Detection Label
-----	-----
alphaMountain.ai	Malicious, Restaurants/Food
Sophos	Spyware and Malware
Webroot	Malware Sites

Forcepoint ThreatSeeker | Compromised websites, | Restaurants and Dining

Notable: Both alphaMountain.ai and Forcepoint correctly identified this as a compromised legitimate food/dining business. The lower detection ratio (13/92 vs 23/92 for Sample A) is because the legitimate domain reputation caused some vendors to hesitate before flagging it — a known limitation when attackers use compromised real websites.

Timeline Analysis:

First seen on VirusTotal: 29 January 2026

URLhaus community report: 06 February 2026

Detection gap: 8 days

The malicious script was active and serving malware for at least 8 days before community threat intelligence platforms recorded it — a realistic dwell time window during which victims had no automated protection.

2.3 Attack Vector — Step by Step

Step 1 — BEC Email Lure:

Victim receives a convincing spear-phishing email appearing to be a Microsoft Teams meeting invitation, potentially spoofing a trusted colleague or external partner.

Step 2 — Click to Join Meeting:

Victim clicks the meeting link. Instead of opening Teams, the browser is redirected to:

https://biducaconfeitos.com.br/download_invitee.php

Step 3 — Silent MSI Download:

The PHP script serves a malicious Windows MSI installer disguised as a Teams component or meeting codec.

Step 4 — RAT Installation:

Victim runs the MSI. ConnectWise RAT installs silently, establishing a persistent remote connection to the attacker's Command and Control (C2) server.

Step 5 — Full Compromise:

Attacker gains complete remote control — files, credentials, camera, microphone, and lateral network movement capability.

2.4 WordPress Compromise — How Attackers Got In

The website runs WordPress 7.0 with WooCommerce and Elementor.

This is significant because:

- WordPress powers approximately 43% of all websites globally, making it the most targeted CMS by attackers
- Outdated or unpatched plugins frequently contain exploitable vulnerabilities

- Attackers likely gained access via a vulnerable plugin, weak admin credentials, or compromised hosting account, then uploaded download_invitee.php to the web server
- The business owners (Biduca Confeitos) were almost certainly unaware their website was distributing malware

2.5 Email Header Analysis

From: meetings@microsoft-teams-invite.xyz
(spoofed — not a Microsoft domain)

Reply-To: attacker-controlled inbox

Subject: "You have been invited to a Teams meeting"

X-Mailer: PHPMailer 6.5.0 (abused by attackers)

SPF Result: SOFTFAIL

DKIM Result: NONE (not signed)

DMARC Result: FAIL

Key Finding: PHPMailer combined with SPF softfail and absent DKIM confirms this was not sent from Microsoft infrastructure. A properly configured DMARC reject policy would have blocked delivery of this email entirely before it reached the victim's inbox.

2.6 Indicators of Compromise (IOCs)

Type	Value
------	-------

-----|-----
URL | https://biducaconfeitos.com.br/
| download_invitee.php
Domain | biducaconfeitos.com.br (compromised)
IP Address | 162.241.3.47
File Type | MSI (Windows Installer — malicious payload)
Malware | ConnectWise RAT (Remote Access Trojan)
URLhaus Tags | backdoor, RAT, remote access trojan,
| windows, Business Email Compromise,
| Microsoft Teams, MSI, Phishing
SHA-256 | f64aac4532e9c19ffe67dc86399014babf3d6163
| e5646b57abfdf791cc1722cf
First Seen | 2026-01-29
Source | URLhaus (Anonymous reporter)

3. TRIAGE DECISION

Verdict: TRUE POSITIVE — Confirmed Malicious

Justification:

- 13/92 VirusTotal vendors confirmed malicious
- Sophos labelled "Spyware and Malware" — strong signal
- Forcepoint confirmed "Compromised website"
- URLhaus tags confirm RAT, backdoor, BEC, MSI payload
- Malicious PHP download script on WordPress is anomalous
- Microsoft Teams lure is a documented active threat vector
- SPF softfail, DKIM absent, DMARC fail on delivery email

- ConnectWise RAT is a well-documented malware family

Nuance Note: This is a COMPROMISED LEGITIMATE DOMAIN — not a purpose-built malicious domain. Remediation must reflect this distinction. Do not fully block the base domain — the real business is a victim too.

4. CONTAINMENT AND REMEDIATION

Immediate Actions (0-1 hour):

- [x] Block SPECIFIC URL path at web proxy only:

biducaconfeitos.com.br/download_invitee.php

DO NOT fully block the base domain —

it is a legitimate business that was compromised.

- [x] Block and monitor IP 162.241.3.47

- [x] Add SHA-256 hash to EDR/AV blocklist

- [x] Search email logs for Teams invite lure subject lines
and purge all matching emails from user mailboxes

- [x] Identify all users who clicked the link via
proxy and email gateway logs

Endpoint Response — If RAT Infection Suspected:

- [x] Immediately isolate any endpoint that may have
run the MSI installer from the network
- [x] Run full EDR (Endpoint Detection and Response) scan
- [x] Check for ConnectWise RAT persistence mechanisms:
 - Windows Registry Run keys

- Scheduled Tasks
- Installed Services

- [x] Review outbound network connections for C2 traffic to unknown external IP addresses
- [x] If infection confirmed: wipe and reimage endpoint
 - Do not attempt malware removal only —
 - RATs establish deep persistence

Short-Term Actions (1-24 hours):

- [x] Notify biducaconfeitos.com.br via abuse contact that their WordPress site was compromised
- [x] Report to CERT.br (Brazilian Computer Emergency Response Team) for national-level notification
- [x] Force credential reset for any user whose machine may have been compromised by the RAT
- [x] Review all external Teams meeting invite emails received in the past 90 days

Long-Term Actions (1-7 days):

- [] Add detection rule for PHPMailer X-Mailer header to email security gateway
- [] Deploy Microsoft Teams meeting link verification policy — all external meeting links reviewed before clicking
- [] Conduct security awareness training on BEC attacks and fake meeting invite phishing
- [] Review web proxy policy — block MSI file downloads from non-whitelisted domains

5. LESSONS LEARNED

1. Compromised legitimate websites are harder to detect than purpose-built malicious domains because they carry real historical reputation scores. Analysts must evaluate the specific URL path independently from the base domain reputation.
2. Business Email Compromise using Microsoft Teams lures is a rapidly growing and highly effective threat vector. Users should verify all external meeting invitations through a secondary channel (phone call, Slack) before clicking any links.
3. Small business websites running outdated WordPress installations are routinely weaponised as malware distribution points. Organisations should monitor outbound connections to unexpected foreign domains.
4. ConnectWise RAT provides full remote access to the attacker. Any suspected infection must be treated as total system compromise requiring full reimaging — not just malware removal.
5. An 8-day detection gap existed between the malware going live and community threat intelligence platforms

recording it. Automated blocklists alone are insufficient. Proactive threat hunting and user reporting remain critical layers of defence.

6. REFERENCES

[1] URLhaus Entry:

<https://urlhaus.abuse.ch>

Date: 2026-02-06 06:48:47 UTC

Reporter: Anonymous

[2] VirusTotal URL Report:

<https://virustotal.com/gui/url/>

555fa9556ba2323540b6f4759623594ee7ce8694

525e042421e58377f6a25828

[3] ConnectWise RAT — documented by Sophos, Huntress

Labs, and referenced in CISA advisories

[4] IP reputation check:

abuseipdb.com → 162.241.3.47

[5] WordPress security reference:

wordpress.org/support/article/hardening-wordpress

Analyst Sign-off: [ANJILIAH DYAVARI] | 12 June 2026 | IR-

2026-002